FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

MK FRAUD INSIGHTS

COMPREHENSIVE FRAUD READINESS REPORT

Fraud exposure, target control environment and implementation programme

70.71
READINESS / 100

DEVELOPING
MATURITY BAND

PREPARED FOR

Fictional Retail Group (extensive unanswered information)

Assessment reference · FX-P5

CONFIDENTIAL · AUTOMATED ANALYSIS · NOT INDEPENDENTLY REVIEWED

Contents

Management report — SECTIONS 1–9

1 · Where the organisation stands

2 · What is driving the position

3 · Where the material fraud exposure sits

4 · Fraud scenario portfolio

5 · The control environment management should build

6 · Who must own the response

7 · Decisions leadership must make

8 · What should happen, and in what order

9 · How management will know it is working

Analytical registers — APPENDICES A–F

A · Finding register	15 entries
B · Fraud risk register	15 entries
C · Control blueprint register	15 entries
D · Evidence requirement register	64 entries
E · 12-month action and assurance register	41 entries
F · Measurement register	15 entries

THE TWO HALVES OF THIS REPORT

Sections 1–9 are the management report: what the assessment shows, what it means, and what to do about it. Appendices A–F are the analytical registers behind those sections. They contain every finding, risk, control design, evidence requirement, action and measure, with the identifiers that connect them. The management sections state nothing the registers do not hold.

BASIS OF THIS REPORT

This report is produced by automated analysis of the recorded MK Fraud Readiness assessment. It has not been independently reviewed. No evidence has been examined, no control has been tested for operating effectiveness, no personnel have been interviewed, and no assurance opinion is given. Assessment positions are self-reported by the organisation. Recommended control designs, evidence requirements and operating measures are MK methodology: what good practice requires, not observations of what the organisation currently does.

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

The assessed readiness position

70.71	Developing	10	15	15
READINESS SCORE OUT OF 100	MATURITY BAND	DOMAINS ASSESSED	MATERIAL FINDINGS	CONTROL DESIGNS RECOMMENDED

Domain readiness profile

Fraud Leadership and Governance	92.31	Strategic
Fraud Risk Identification	88.57	Strategic
Operational Fraud Controls	57.78	Developing
Fraud Detection Capability	84.29	Strategic
Fraud Incident Response	89.52	Strategic
Whistleblowing and Reporting Culture	86.00	Strategic
Third-Party and Supply Chain Fraud Risk	37.27	Reactive
Digital and Identity Fraud Risk	18.62	Reactive
Fraud Culture and Awareness	90.00	Strategic
Continuous Improvement and Fraud Risk Monitoring	90.91	Strategic

Ordered as assessed. Positions are self-reported through the assessment and have not been independently verified.

EXECUTIVE INTERPRETATION

Management interpretation is added at generation. The analysis on this page stands without it.

The patterns beneath the score

The assessment produced 15 material findings. They resolve into 8 connected patterns, ordered by how much of the organisation's critical control population each one affects.

PATTERN	FINDINGS	CRITICAL	HARD GATE	MANAGEMENT QUESTION THIS RAISES
Identity and access challenge Operational Fraud Controls · Digital and Identity Fraud Risk	5	3	3	Is authority verified at the points where it can be misused?
Detection and exception review Digital and Identity Fraud Risk	1	1	1	Would unusual activity be seen and challenged in time?
Supplier and payment integrity Third-Party and Supply Chain Fraud Risk	3	Not recorded	Not recorded	Can value be redirected before anyone independently challenges it?
Culture and continuous improvement Digital and Identity Fraud Risk	2	Not recorded	Not recorded	Do people recognise fraud, and does the control environment learn?
payroll integrity Operational Fraud Controls	1	Not recorded	Not recorded	What does this capability require?
cash custody Operational Fraud Controls	1	Not recorded	Not recorded	What does this capability require?
stock asset custody Operational Fraud Controls	1	Not recorded	Not recorded	What does this capability require?
Incident response and evidence integrity Digital and Identity Fraud Risk	1	Not recorded	Not recorded	When something is suspected, can we contain it and keep the evidence?

Every finding behind these patterns is listed in Appendix A.

> **WHY THIS MATTERS**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

Exposure by control family

15 fraud risks arise from the assessed position. They concentrate in 8 exposure families.

EXPOSURE FAMILY	RISKS	DOMAINS AFFECTED	WHAT THE ORGANISATION IS EXPOSED TO
Identity and access challenge	5	D8 · D3	Is authority verified at the points where it can be misused?
Supplier and payment integrity	3	D7	Can value be redirected before anyone independently challenges it?
Culture and continuous improvement	2	D8	Do people recognise fraud, and does the control environment learn?
Detection and exception review	1	D8	Would unusual activity be seen and challenged in time?
payroll integrity	1	D3	What does this capability require?
cash custody	1	D3	What does this capability require?
stock asset custody	1	D3	What does this capability require?
Incident response and evidence integrity	1	D8	When something is suspected, can we contain it and keep the evidence?

Full risk statements, causes and treatment directions are in Appendix B. Risks are derived from assessed control positions; no likelihood or monetary value is assigned, because the assessment does not support one.

> **MANAGEMENT IMPLICATION**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

Fraud scenario portfolio

Conditional pathways derived from the recorded control position. Each shows how it could begin, how it could progress, the control response that would interrupt it, and what management could observe first. No allegation that any event has occurred.

PATHWAY	HOW IT COULD BEGIN	HOW IT COULD PROGRESS	INTERRUPTION POINT	WARNING INDICATORS	LINKS
A compromised or impersonated identity is used to change a sensitive profile, instruction or transaction IDENTITY IMPERSONATION	A customer account, payment instruction or profile is created or materially changed through a digital channel without an independent verification step.	An actor uses an impersonated or insufficiently verified identity to obtain payment, credit or account authority through the organisation's digital channel.	Security Operations must monitor authentication, credential, profile, device and transaction signals across material identity-bearing systems, define takeover indicators and alert thresholds, and route suspected identity misuse into the separate investigation and containment process.; The process owner must define the risk points requiring verification, including customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting. Apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records and confirmation of contact details through independently obtained channels. Retain results and evidence under applicable data-protection obligations, require documented approval for exceptions, and trigger re-verification for sensitive profile or banking changes.	• Activation before verification, an unapproved exception, or a sensitive change without re-verification. • An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population. • Credential reset, device change or profile amendment • Identity data differs across trusted records • Sensitive transaction follows a new or unusual session	RISK-001, RISK-002
Unusual activity avoids timely challenge because monitoring or escalation coverage is incomplete DETECTION EVASION	A refund, credit note or manual adjustment falls outside the expected pattern without a timely review route.	An actor keeps refunds, credits or adjustments individually small and routine so they remain below or outside the available monitoring and exception thresholds.	The security monitoring owner inventories material login, privilege, profile and transaction events, implements risk rules across the full in-scope event feed, assigns alerts to trained analysts, preserves dispositions and escalates high-risk account compromise immediately; monthly tuning uses confirmed true/false positives.	• An exception, access, approval or incident record that cannot be reconciled to the complete in-scope population. • Priority feed outage, high-risk alert outside SLA or confirmed compromise not escalated. • Repeated low-value or threshold-adjacent activity • Alert or exception backlog grows without assigned owner • Monitoring rule is not updated after a material process change	RISK-003

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

PATHWAY	HOW IT COULD BEGIN	HOW IT COULD PROGRESS	INTERRUPTION POINT	INDICATORS	LINKS
Third-party relationship manipulation or collusion escapes timely challenge THIRD PARTY COLLUSION	A third-party relationship continues, or changes, without the review the organisation intends to apply to it.	An actor uses the gap left by that weakness to obtain value or advantage through the relationship while it continues to appear routine.	The Governing body / independent oversight must commission periodic independent review of procurement and vendor management covering all vendor-master creations and amendments with approver identity, award patterns by buyer and supplier, spend outside approved contracts or thresholds, use of emergency and single-source routes, and policy exception volumes by individual; findings are reported to governance with owners and due dates and tracked to closure.	• A procurement or vendor-master review is overdue • Exceptions concentrate with one individual without investigation • A third-party relationship or the decision affecting it proceeds without independent challenge	RISK-011

The control programmes

The 15 recommended control designs group into 8 programmes. Each is one coherent piece of work with one accountable executive.

PROGRAMME	CONTROLS	EVIDENCE	MEASURES	ACCOUNTABLE	HORIZON
Identity and access challenge	5	18	5	Chief Operating Officer	60 days, 90 days
Supplier and payment integrity	3	14	3	Chief Financial Officer	60 days, 90 days
Culture and continuous improvement	2	8	2	Chief Technology Officer	90 days, 60 days
payroll integrity	1	5	1	Chief Financial Officer	60 days
cash custody	1	5	1	Chief Financial Officer	60 days
stock asset custody	1	5	1	Chief Operating Officer	90 days
Detection and exception review	1	4	1	Chief Technology Officer	90 days
Incident response and evidence integrity	1	5	1	Chief Technology Officer	90 days

Individual control designs are in Appendix C; the evidence each requires is in Appendix D.

> **CONTROL PROGRAMME SYNTHESIS**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

Programme detail

Identity and access challenge

5 CONTROLS

Is authority verified at the points where it can be misused?

Accountable: Chief Operating Officer
Evidence expected · 18 items across 5 controls
Delivery horizon: 60 days, 90 days
Effectiveness measures · 5

Controls: CI-D3-Q04, CI-D3-Q08, CI-D8-Q01, CI-D8-Q08, CI-D8-Q09

Supplier and payment integrity

3 CONTROLS

Can value be redirected before anyone independently challenges it?

Accountable: Chief Financial Officer
Evidence expected · 14 items across 3 controls
Delivery horizon: 60 days, 90 days
Effectiveness measures · 3

Controls: CI-D7-Q02, CI-D7-Q05, CI-D7-Q06

Culture and continuous improvement

2 CONTROLS

Do people recognise fraud, and does the control environment learn?

Accountable: Chief Technology Officer
Evidence expected · 8 items across 2 controls
Delivery horizon: 90 days, 60 days
Effectiveness measures · 2

Controls: CI-D8-Q03, CI-D8-Q06

Programme detail

payroll integrity

1 CONTROLS

What does this capability require?

Accountable: Chief Financial Officer
Evidence expected · 5 items across 1 controls

Delivery horizon: 60 days
Effectiveness measures · 1

Controls: CI-D3-Q09

cash custody

1 CONTROLS

What does this capability require?

Accountable: Chief Financial Officer
Evidence expected · 5 items across 1 controls

Delivery horizon: 60 days
Effectiveness measures · 1

Controls: CI-D3-Q10

stock asset custody

1 CONTROLS

What does this capability require?

Accountable: Chief Operating Officer
Evidence expected · 5 items across 1 controls

Delivery horizon: 90 days
Effectiveness measures · 1

Controls: CI-D3-Q11

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

Programme detail

Detection and exception review

1 CONTROLS

Would unusual activity be seen and challenged in time?

Accountable: Chief Technology Officer
Evidence expected · 4 items across 1 controls

Delivery horizon: 90 days
Effectiveness measures · 1

Controls: CI-D8-Q02

Incident response and evidence integrity

1 CONTROLS

When something is suspected, can we contain it and keep the evidence?

Accountable: Chief Technology Officer
Evidence expected · 5 items across 1 controls

Delivery horizon: 90 days
Effectiveness measures · 1

Controls: CI-D8-Q10

The governance model

Accountability is expressed as roles, not individuals. The assessment does not identify people, and this report does not infer them.

ROLE	STANDING	CONTROLS	DECISIONS	EVIDENCE	ESCALATION RESPONSIBILITY
Chief Technology Officer	executive accountability	6	6	Not recorded	Not recorded
Chief Operating Officer	executive accountability	4	Not recorded	Not recorded	Not recorded
Chief Financial Officer	executive accountability	4	Not recorded	Not recorded	Not recorded
Audit Committee Chair	executive accountability	1	Not recorded	Not recorded	Not recorded
Technology and information security	process ownership	8	Not recorded	31	Priority feed outage, high-risk alert outside SLA or confirmed compromise not escalated.
Procurement and vendor management	process ownership	2	Not recorded	10	Not recorded
Payroll	process ownership	1	Not recorded	5	Not recorded
Site operations	process ownership	1	Not recorded	5	Not recorded
Operations, Stores	process ownership	1	Not recorded	5	Not recorded
Named business process owners	process ownership	1	Not recorded	4	Not recorded
Risk function	process ownership	Not recorded	Not recorded	Not recorded	Any missed quarterly review, unassigned account or removal overdue beyond 10 business days.
Finance and payment operations	process ownership	Not recorded	Not recorded	Not recorded	A sensitive payroll change released without review, unexplained duplicate or ghost record, or unresolved exception at payment release.
Internal Audit	oversight	1	Not recorded	4	Criteria set or changed after bid opening, an undeclared conflict, or unjustified single-source award.
Audit Committee	oversight	Not recorded	Not recorded	Not recorded	Review overdue, or a concentration of exceptions by one individual not investigated.

The decision agenda

DECISION	WHY NOW	RECOMMENDED DIRECTION	OWNER	CONSEQUENCE OF DELAY
Approve accountable executive mandates and escalation authority for priority remediation.	Hard-gate, governance and maturity-limiting controls require authority to allocate resources and resolve blockers.	Name one accountable executive per linked control and approve a 30-day escalation route.	Chief Technology Officer 60 days	Priority controls remain ownerless or blocked and the maturity reading remains constrained.
Choose and record remediation rather than passive acceptance for Critical and High risks.	Plausible consequence pathways require an explicit leadership treatment decision.	Approve linked treatments; any temporary acceptance must name an owner, expiry and compensating control.	Chief Technology Officer 60 days	Known risk pathways remain untreated without a documented acceptance basis.
Approve the target control standards management will implement across the priority risk areas.	Functions need one design baseline rather than independent interpretations of the findings.	Adopt the control-improvement register; deviations require documented oversight approval.	Chief Technology Officer 60 days	Partial or inconsistent designs fail to address the causal pathway.
Approve specialist capacity and resources for high-difficulty controls.	High-difficulty controls cannot meet target periods without committed capacity.	Fund the named supporting functions and require a resource-confirmed delivery plan.	Chief Technology Officer 60 days	The highest-complexity gaps remain open despite nominal approval.
Approve prerequisite-first sequencing for dependent improvements.	Dependent controls cannot operate reliably before prerequisite ownership, data or processes exist.	Use authoritative roadmap dependency IDs and escalate threatened prerequisites.	Chief Technology Officer 60 days	Downstream controls are implemented on incomplete foundations.
Approve a fixed fraud-risk implementation and control-effectiveness review cadence.	The linked registers require continuing governance to become a managed programme.	Require monthly implementation reporting and quarterly control-effectiveness review through the organisation's management and oversight route.	Chief Technology Officer 60 days	Actions lose momentum, exceptions remain open and management receives the control position too late to intervene.

A recommended direction is MK methodology. The decision remains management's.

The 12-month implementation programme

15 implementation actions, followed by 13 embed-and-evidence checkpoints, and 13 assure-and-review checkpoints across the 12-month programme. 41 programme objects in total, each with an owner, a deliverable and a test that shows it is complete.

HORIZON	WORK TYPE	COUNT	PROGRAMMES ADVANCED IN THIS HORIZON
60 days	Implement	8	Identity and access challenge · Culture and continuous improvement · payroll integrity · cash custody · Supplier and payment integrity
90 days	Implement	7	Detection and exception review · Identity and access challenge · Supplier and payment integrity · stock asset custody · Culture and continuous improvement · Incident response and evidence integrity
3-6 months	Embed & evidence	13	Identity and access challenge · payroll integrity · cash custody · stock asset custody · Supplier and payment integrity · Detection and exception review · Culture and continuous improvement · Incident response and evidence integrity
6-12 months	Assure & review	13	Identity and access challenge · payroll integrity · cash custody · stock asset custody · Supplier and payment integrity · Detection and exception review · Culture and continuous improvement · Incident response and evidence integrity

Every programme item, with its dependency and completion criterion, is in Appendix E.

> **IMPLEMENTATION SYNTHESIS**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

The measurement framework

Each programme carries effectiveness measures drawn from the control designs behind it. These are the signals management should expect to see, not a claim that they exist today.

PROGRAMME	MEASURES	CONTROLS	ACCOUNTABLE FOR REPORTING
Identity and access challenge	5	5	Chief Operating Officer
Supplier and payment integrity	3	3	Chief Financial Officer
Culture and continuous improvement	2	2	Chief Technology Officer
payroll integrity	1	1	Chief Financial Officer
cash custody	1	1	Chief Financial Officer
stock asset custody	1	1	Chief Operating Officer
Detection and exception review	1	1	Chief Technology Officer
Incident response and evidence integrity	1	1	Chief Technology Officer

The individual measures are in Appendix F.

> **CONCLUSION**
>
> Management interpretation is added at generation. The analysis on this page stands without it.

Finding register

Every material finding the assessment produced. "Assessment indication" is what the responses record; it is self-reported and has not been verified.

ID	DOMAIN	ASSESSMENT INDICATION	MATERIALITY	FRAUD MECHANISM	RISK	CONTROL
MF-D8-Q02 D8-Q02	Digital and Identity Fraud Risk	Not in place This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	maturity constraint GATE	Account compromise or misuse can persist when anomalous login, access or transaction patterns are not surfaced and investigated.	RISK-DIGITAL-MISUSE	CI-D8-Q02
MF-D3-Q04 D3-Q04	Operational Fraud Controls	Partially designed This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	maturity constraint GATE	Access granted without a current role basis can enable a person to initiate, approve or alter activity beyond legitimate responsibility.	RISK-UNAUTHORISED-ACCESS	CI-D3-Q04
MF-D8-Q08 D8-Q08	Digital and Identity Fraud Risk	Initial / ad hoc This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	control failure GATE	Identity misuse can continue when takeover, impersonation and unusual identity-bearing activity are not surfaced for timely challenge.	RISK-CONTROL-D8-Q08	CI-D8-Q08
MF-D8-Q01 D8-Q01	Digital and Identity Fraud Risk	Partially designed This recorded weakness affects a methodology hard gate and must be remediated before relying on the aggregate maturity result.	control failure GATE	An unverified or impersonated identity allows a fraudulent party to receive goods, payments, credit, benefits or system access under someone else's name.	RISK-CONTROL-D8-Q01	CI-D8-Q01
MF-D7-Q06 D7-Q06	Third-Party and Supply Chain Fraud Risk	Not in place This recorded response and its surrounding exposure make the control materially relevant.	control failure	Procurement and vendor-master roles can both create the payee and direct the spend, so without external oversight the function can authorise its own diversion route.	RISK-CONTROL-D7-Q06	CI-D7-Q06
MF-D8-Q06 D8-Q06	Digital and Identity Fraud Risk	Not in place This recorded response and its surrounding exposure make the control materially relevant.	control failure	Account compromise is often first noticed by the account holder, and a slow or unknown reporting route wastes the short window in which containment prevents loss.	RISK-CONTROL-D8-Q06	CI-D8-Q06
MF-D3-Q09 D3-Q09	Operational Fraud Controls	Initial / ad hoc This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	An unauthorised bank, pay-rate or employee-record change, duplicate or ghost employee can divert payroll value before the payment run is released.	RISK-CONTROL-D3-Q09	CI-D3-Q09
MF-D3-Q10 D3-Q10	Operational Fraud Controls	Initial / ad hoc This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Weak custody and delayed reconciliation can allow cash shortages, diversion or concealment within ordinary operational variance.	RISK-CONTROL-D3-Q10	CI-D3-Q10
MF-D3-Q11 D3-Q11	Operational Fraud Controls	Initial / ad hoc This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Uncontrolled movement, inaccurate counts or unsupported write-offs can conceal theft, diversion or unauthorised disposal of physical value.	RISK-CONTROL-D3-Q11	CI-D3-Q11
MF-D7-Q02 D7-Q02	Third-Party and Supply Chain Fraud Risk	Initial / ad hoc This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Manipulated specifications, leaked pricing or rotated winning bids let a favoured supplier win at inflated prices while the process appears competitive on file.	RISK-CONTROL-D7-Q02	CI-D7-Q02

MF-D7-Q05 D7-Q05	Third-Party and Supply Chain Fraud Risk	Initial / ad hoc This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	A supplier verified once can change ownership, subcontract to an undisclosed party or drift into inflated pricing, and nothing re-tests the original assurance.	RISK-CONTROL-D7-Q05	CI-D7-Q05
MF-D8-Q03 D8-Q03	Digital and Identity Fraud Risk	Initial / ad hoc This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Most payment-diversion and account-compromise attacks begin with a convincing message to a person, so the workforce is the control surface that is actually attacked.	RISK-CONTROL-D8-Q03	CI-D8-Q03
MF-D8-Q09 D8-Q09	Digital and Identity Fraud Risk	Initial / ad hoc This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Access that was once justified can remain available after role change or operational change and enable unauthorised alteration or concealment.	RISK-CONTROL-D8-Q09	CI-D8-Q09
MF-D3-Q08 D3-Q08	Operational Fraud Controls	Partially designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Stale access after role change or exit can be used to initiate, change or conceal activity outside current responsibilities.	RISK-CONTROL-D3-Q08	CI-D3-Q08
MF-D8-Q10 D8-Q10	Digital and Identity Fraud Risk	Partially designed This recorded response and its surrounding exposure make the control materially relevant.	cross domain dependency	Without a tested response route, an identity compromise can continue after detection and its scope, losses and affected parties may remain unclear.	RISK-CONTROL-D8-Q10	CI-D8-Q10

Fraud risk register

Risks implied by the assessed control positions. No likelihood, monetary value or incident frequency is assigned, because the assessment does not support one.

ID	RISK	CURRENT CONTROL POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-CONTROL-D8-Q01 MF-D8-Q01	**Because the self-assessment records "The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm" as "Partially designed"; the expected control standard is therefore not yet met, there is a risk that an unverified or impersonated identity allows a fraudulent party to receive goods, payments, credit, benefits or system access under someone else's name. Consequence pathway: compromised or privileged access can alter records and transactions; Digital misuse can evade prevention and monitoring.**	Digital and Identity Fraud Risk: Partially designed: Partially designed but not fully implemented	The process owner must define the risk points requiring verification, including customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting. Apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records and confirmation of contact details through independently obtained channels. Retain results and evidence under applicable data-protection obligations, require documented approval for exceptions, and trigger re-verification for sensitive profile or banking changes.	COO / CFO
RISK-CONTROL-D8-Q08 MF-D8-Q08	**Because the self-assessment records "The organisation can detect identity misuse, account takeover or impersonation" as "Initial / ad hoc"; the expected control standard is therefore not yet met, there is a risk that identity misuse can continue when takeover, impersonation and unusual identity-bearing activity are not surfaced for timely challenge. Consequence pathway: compromised or privileged access can alter records and transactions; Digital misuse can evade prevention and monitoring.**	Digital and Identity Fraud Risk: Initial / ad hoc: Exists only informally or inconsistently	Security Operations must monitor authentication, credential, profile, device and transaction signals across material identity-bearing systems, define takeover indicators and alert thresholds, and route suspected identity misuse into the separate investigation and containment process.	Chief Technology Officer
RISK-DIGITAL-MISUSE MF-D8-Q02	**Because material login, access, profile and transaction events are not completely monitored and triaged, there is a risk that a compromised or malicious identity uses digital channels without timely detection and response. Consequence pathway: customers and partners lose trust in digital channels; digital operations must contain and investigate a wider incident; security or personal-data notification duties may arise; unauthorised transactions or account changes cause direct loss.**	Digital and Identity Fraud Risk: Not in place: No control exists	The security monitoring owner inventories material login, privilege, profile and transaction events, implements risk rules across the full in-scope event feed, assigns alerts to trained analysts, preserves dispositions and escalates high-risk account compromise immediately; monthly tuning uses confirmed true/false positives.	Chief Technology Officer
RISK-UNAUTHORISED-ACCESS MF-D3-Q04	**Because role-based access is not completely reviewed and removed when responsibilities change, there is a risk that a user or compromised credential uses excess access to initiate, approve or conceal unauthorised activity. Consequence pathway: data or access-control obligations may be breached; stakeholders lose trust in system integrity; system records and segregation of duties cannot be relied upon; transactions or assets are manipulated for direct loss.**	Operational Fraud Controls: Partially designed: Partially designed but not fully implemented	System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.	COO

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

ID	Risk	Position	Required treatment	Owner role
RISK-CONTROL-D3-Q08 MF-D3-Q08	**Because the self-assessment records "System and data access is reviewed periodically and removed when no longer required" as "Partially designed"; the expected control standard is therefore not yet met, there is a risk that stale access after role change or exit can be used to initiate, change or conceal activity outside current responsibilities. Consequence pathway: access or supplier-control weakness can enable unauthorised payments or manipulation; Preventive controls may not match current roles or approved suppliers.**	Operational Fraud Controls: Partially designed: Partially designed but not fully implemented	System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	COO
RISK-CONTROL-D3-Q09 MF-D3-Q09	**Because the self-assessment records "Payroll master-file changes and unusual payroll records receive review before payment" as "Initial / ad hoc"; the expected control standard is therefore not yet met, there is a risk that an unauthorised bank, pay-rate or employee-record change, duplicate or ghost employee can divert payroll value before the payment run is released. Consequence pathway: access or supplier-control weakness can enable unauthorised payments or manipulation; Preventive controls may not match current roles or approved suppliers.**	Operational Fraud Controls: Initial / ad hoc: Exists only informally or inconsistently	Payroll and Human Resources must reconcile joiner, mover and leaver records to the payroll master file before each payment run, independently review bank-account and pay-rate changes, test for duplicate or ghost records and unusual payments, and retain reviewer decisions and exception closure before release.	Chief Financial Officer / Chief People Officer
RISK-CONTROL-D3-Q10 MF-D3-Q10	**Because the self-assessment records "Physical cash is counted, safeguarded and reconciled by defined people" as "Initial / ad hoc"; the expected control standard is therefore not yet met, there is a risk that weak custody and delayed reconciliation can allow cash shortages, diversion or concealment within ordinary operational variance. Consequence pathway: access or supplier-control weakness can enable unauthorised payments or manipulation; Preventive controls may not match current roles or approved suppliers.**	Operational Fraud Controls: Initial / ad hoc: Exists only informally or inconsistently	Finance and site managers must assign cash custodians, perform opening and closing counts with independent review, reconcile takings to receipts and bankings, record sealed transfers and investigate every shortage or overage against a defined threshold before the next cycle closes.	Chief Financial Officer / Chief Operating Officer
RISK-CONTROL-D3-Q11 MF-D3-Q11	**Because the self-assessment records "Stock and physical assets are safeguarded and reconciled by defined people" as "Initial / ad hoc"; the expected control standard is therefore not yet met, there is a risk that uncontrolled movement, inaccurate counts or unsupported write-offs can conceal theft, diversion or unauthorised disposal of physical value. Consequence pathway: access or supplier-control weakness can enable unauthorised payments or manipulation; Preventive controls may not match current roles or approved suppliers.**	Operational Fraud Controls: Initial / ad hoc: Exists only informally or inconsistently	Operations and Finance must maintain a complete stock and asset register, assign custodians, require authorised movement and disposal records, perform risk-based counts across locations, reconcile results to the ledger or inventory system and independently approve write-offs and investigate shrinkage exceptions.	Chief Operating Officer / Chief Financial Officer
RISK-CONTROL-D7-Q02 MF-D7-Q02	**Because the self-assessment records "Procurement processes include safeguards against collusion, manipulation, bid rigging or favouritism" as "Initial / ad hoc"; the expected control standard is therefore not yet met, there is a risk that manipulated specifications, leaked pricing or rotated winning bids let a favoured supplier win at inflated prices while the process appears competitive on file. Consequence pathway: false suppliers, invoices or bank changes can redirect payments; Vendor and payment integrity can be bypassed.**	Third-Party and Supply Chain Fraud Risk: Initial / ad hoc: Exists only informally or inconsistently	The procurement owner must require, above defined thresholds, that evaluation criteria and weightings are fixed and recorded before submissions are opened, submissions remain sealed until a scheduled opening witnessed by at least two people, evaluation is performed by a panel with signed conflict declarations, and single-source or emergency awards require documented justification and independent approval; a periodic analysis reviews award concentration, repeated near-identical pricing and rotating winners.	CFO / COO

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

ID	Risk	Position	Required treatment	Owner role
RISK-CONTROL-D7-Q05 MF-D7-Q05	**Because the self-assessment records "High-risk suppliers or third-party relationships are periodically monitored or reviewed" as "Initial / ad hoc"; the expected control standard is therefore not yet met, there is a risk that a supplier verified once can change ownership, subcontract to an undisclosed party or drift into inflated pricing, and nothing re-tests the original assurance. Consequence pathway: false suppliers, invoices or bank changes can redirect payments; Vendor and payment integrity can be bypassed.**	Third-Party and Supply Chain Fraud Risk: Initial / ad hoc: Exists only informally or inconsistently	The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the CFO.	CFO / COO
RISK-CONTROL-D7-Q06 MF-D7-Q06	**Because the self-assessment records "Procurement or vendor-management activity is subject to oversight or periodic review" as "Not in place"; the expected control standard is therefore not yet met, there is a risk that procurement and vendor-master roles can both create the payee and direct the spend, so without external oversight the function can authorise its own diversion route. Consequence pathway: false suppliers, invoices or bank changes can redirect payments; Vendor and payment integrity can be bypassed.**	Third-Party and Supply Chain Fraud Risk: Not in place: No control exists	The audit committee must commission periodic independent review of procurement and vendor management covering all vendor-master creations and amendments with approver identity, award patterns by buyer and supplier, spend outside approved contracts or thresholds, use of emergency and single-source routes, and policy exception volumes by individual; findings are reported to governance with owners and due dates and tracked to closure.	Audit Committee Chair / CFO
RISK-CONTROL-D8-Q03 MF-D8-Q03	**Because the self-assessment records "Employees receive training on phishing, social engineering and digital impersonation attempts" as "Initial / ad hoc"; the expected control standard is therefore not yet met, there is a risk that most payment-diversion and account-compromise attacks begin with a convincing message to a person, so the workforce is the control surface that is actually attacked. Consequence pathway: compromised or privileged access can alter records and transactions; Digital misuse can evade prevention and monitoring.**	Digital and Identity Fraud Risk: Initial / ad hoc: Exists only informally or inconsistently	The security awareness owner must deliver role-relevant training covering payment-instruction and bank-detail-change requests, executive impersonation, urgency and secrecy pressure, credential-harvesting pages and voice or messaging impersonation; reinforce with periodic simulations targeted at high-risk roles such as finance and procurement, measure report rate as well as click rate, provide a one-click reporting route with feedback, and require verification through an independently obtained channel for any payment or bank-detail instruction.	Chief Technology Officer / Chief People Officer
RISK-CONTROL-D8-Q06 MF-D8-Q06	**Because the self-assessment records "Employees and users know how to report suspicious digital activity or account-security concerns" as "Not in place"; the expected control standard is therefore not yet met, there is a risk that account compromise is often first noticed by the account holder, and a slow or unknown reporting route wastes the short window in which containment prevents loss. Consequence pathway: compromised or privileged access can alter records and transactions; Digital misuse can evade prevention and monitoring.**	Digital and Identity Fraud Risk: Not in place: No control exists	The security operations owner must publish a clearly signposted route for staff and, where relevant, external users to report suspicious messages, unexpected account changes and suspected compromise, define monitored hours and target response times, connect reports directly into the alert triage and incident-response process, provide acknowledgement and outcome feedback, and track reporting volume and response time against target.	Chief Technology Officer
RISK-CONTROL-D8-Q09 MF-D8-Q09	**Because the self-assessment records "Sensitive access and administrator rights are reviewed periodically" as "Initial / ad hoc"; the expected control standard is therefore not yet met, there is a risk that access that was once justified can remain available after role change or operational change and enable unauthorised alteration or concealment. Consequence pathway: compromised or privileged access can alter records and transactions; Digital misuse can evade prevention and monitoring.**	Digital and Identity Fraud Risk: Initial / ad hoc: Exists only informally or inconsistently	IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	Chief Technology Officer

ID	RISK	POSITION	REQUIRED TREATMENT	OWNER ROLE
RISK-CONTROL-D8-Q10 MF-D8-Q10	**Because the self-assessment records "The organisation can investigate and contain identity misuse, account takeover or impersonation" as "Partially designed"; the expected control standard is therefore not yet met, there is a risk that without a tested response route, an identity compromise can continue after detection and its scope, losses and affected parties may remain unclear. Consequence pathway: compromised or privileged access can alter records and transactions; Digital misuse can evade prevention and monitoring.**	Digital and Identity Fraud Risk: Partially designed: Partially designed but not fully implemented	Security Operations and Fraud Operations must maintain a response runbook for identity misuse covering session revocation, credential reset, account hold, customer or employee contact, evidence preservation, scope assessment, recovery, escalation and closure; the runbook is exercised periodically and material cases receive independent review.	Chief Technology Officer / Chief Operating Officer

Control blueprint register

Recommended control standard for each finding. This is MK methodology: what good practice requires, not a description of what the organisation currently operates. The assessed state column records what the organisation reported for that control.

ASSESSED STATE KEY

- Partially designed: Partially designed but not fully implemented.; self-assessed and not independently verified.
- Initial / ad hoc: Exists only informally or inconsistently.; self-assessed and not independently verified.
- Not in place: No control exists.; self-assessed and not independently verified.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OWNER / OVERSIGHT	FREQUENCY	EFFECTIVENESS TEST
CI-D3-Q04 D3-Q04 60 days	**Close the material control weakness recorded for "System and data access is granted against current role requirements".**	System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.	STATE 1	Business system owners Risk / Internal Audit	Quarterly and on every joiner, mover or leaver event	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
CI-D3-Q08 D3-Q08 60 days	**Close the material control weakness recorded for "System and data access is reviewed periodically and removed when no longer required".**	System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	STATE 1	Business system owners Risk / Internal Audit	Quarterly and on every joiner, mover or leaver event	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.
CI-D3-Q09 D3-Q09 60 days	**Close the material control weakness recorded for "Payroll master-file changes and unusual payroll records receive review before payment".**	Payroll and Human Resources must reconcile joiner, mover and leaver records to the payroll master file before each payment run, independently review bank-account and pay-rate changes, test for duplicate or ghost records and unusual payments, and retain reviewer decisions and exception closure before release.	STATE 2	Payroll and Human Resources Finance Control / Internal Audit	Before every payroll payment run; monthly trend review	Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.
CI-D3-Q10 D3-Q10 60 days	**Close the material control weakness recorded for "Physical cash is counted, safeguarded and reconciled by defined people".**	Finance and site managers must assign cash custodians, perform opening and closing counts with independent review, reconcile takings to receipts and bankings, record sealed transfers and investigate every shortage or overage against a defined threshold before the next cycle closes.	STATE 2	Site operations and Finance Finance Control / Internal Audit	Each cash-handling shift/day; monthly exception and trend review	All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.
CI-D3-Q11 D3-Q11 90 days	**Close the material control weakness recorded for "Stock and physical assets are safeguarded and reconciled by defined people".**	Operations and Finance must maintain a complete stock and asset register, assign custodians, require authorised movement and disposal records, perform risk-based counts across locations, reconcile results to the ledger or inventory system and independently approve write-offs and investigate shrinkage exceptions.	STATE 2	Operations, Stores and Asset Management Finance Control / Internal Audit	Movement on each event; periodic counts; monthly exception review	All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

ID	OBJECTIVE	RECOMMENDED DESIGN	ASSESSED	OVERSIGHT	FREQUENCY	TEST
CI-D7-Q02 D7-Q02 60 days	**Close the material control weakness recorded for "Procurement processes include safeguards against collusion, manipulation, bid rigging or favouritism".**	The procurement owner must require, above defined thresholds, that evaluation criteria and weightings are fixed and recorded before submissions are opened, submissions remain sealed until a scheduled opening witnessed by at least two people, evaluation is performed by a panel with signed conflict declarations, and single-source or emergency awards require documented justification and independent approval; a periodic analysis reviews award concentration, repeated near-identical pricing and rotating winners.	STATE 2	Procurement lead Internal Audit / Risk	Per qualifying sourcing event; award-pattern analysis at least twice a year	100% of above-threshold awards follow the documented competitive process with declared conflicts and justified exceptions.
CI-D7-Q05 D7-Q05 90 days	**Close the material control weakness recorded for "High-risk suppliers or third-party relationships are periodically monitored or reviewed".**	The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the CFO.	STATE 2	Procurement / Vendor Risk Risk / Internal Audit	Risk-based cycle, at minimum annually for high-risk third parties	100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.
CI-D7-Q06 D7-Q06 90 days	**Close the material control weakness recorded for "Procurement or vendor-management activity is subject to oversight or periodic review".**	The audit committee must commission periodic independent review of procurement and vendor management covering all vendor-master creations and amendments with approver identity, award patterns by buyer and supplier, spend outside approved contracts or thresholds, use of emergency and single-source routes, and policy exception volumes by individual; findings are reported to governance with owners and due dates and tracked to closure.	STATE 3	Internal Audit or independent reviewer Audit Committee	At least annually, with continuous vendor-master change logging	An independent procurement and vendor-management review is completed each period with findings closed by due date.
CI-D8-Q01 D8-Q01 60 days	**Close the material control weakness recorded for "The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm".**	The process owner must define the risk points requiring verification, including customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting. Apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records and confirmation of contact details through independently obtained channels. Retain results and evidence under applicable data-protection obligations, require documented approval for exceptions, and trigger re-verification for sensitive profile or banking changes.	STATE 1	Process owners for onboarding and activation Risk / Compliance	At every defined risk point and on sensitive change	100% of in-scope enrolments and activations carry completed verification before activation, with all exceptions approved.
CI-D8-Q02 D8-Q02 90 days	**Close the material control weakness recorded for "The organisation monitors suspicious access, account or transaction behaviour across its relevant systems and digital channels, including through provider reporting where a third party operates the channel".**	The security monitoring owner inventories material login, privilege, profile and transaction events, implements risk rules across the full in-scope event feed, assigns alerts to trained analysts, preserves dispositions and escalates high-risk account compromise immediately; monthly tuning uses confirmed true/false positives.	STATE 3	Security monitoring / SOC Information Security / Risk	Continuous monitoring; monthly rule tuning	All priority event feeds monitored and 95% of high-risk alerts triaged within SLA.

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

ID	Objective	Recommended design	Assessed	Oversight	Frequency	Test
CI-D8-Q03 D8-Q03 90 days	**Close the material control weakness recorded for "Employees receive training on phishing, social engineering and digital impersonation attempts".**	The security awareness owner must deliver role-relevant training covering payment-instruction and bank-detail-change requests, executive impersonation, urgency and secrecy pressure, credential-harvesting pages and voice or messaging impersonation; reinforce with periodic simulations targeted at high-risk roles such as finance and procurement, measure report rate as well as click rate, provide a one-click reporting route with feedback, and require verification through an independently obtained channel for any payment or bank-detail instruction.	STATE 2	Security awareness owner Information Security / Risk	At induction, at least annually, with periodic simulations	At least 95% completion, improving report rate and declining click rate across successive simulations.
CI-D8-Q06 D8-Q06 60 days	**Close the material control weakness recorded for "Employees and users know how to report suspicious digital activity or account-security concerns".**	The security operations owner must publish a clearly signposted route for staff and, where relevant, external users to report suspicious messages, unexpected account changes and suspected compromise, define monitored hours and target response times, connect reports directly into the alert triage and incident-response process, provide acknowledgement and outcome feedback, and track reporting volume and response time against target.	STATE 3	Security operations Information Security / Risk	Continuous intake within defined monitored hours	At least 95% of reports acknowledged within the target time and routed into triage.
CI-D8-Q08 D8-Q08 90 days	**Close the material control weakness recorded for "The organisation can detect identity misuse, account takeover or impersonation".**	Security Operations must monitor authentication, credential, profile, device and transaction signals across material identity-bearing systems, define takeover indicators and alert thresholds, and route suspected identity misuse into the separate investigation and containment process.	STATE 2	Security operations with identity owners Information Security / Risk	Continuous logging and alerting; runbook exercised at least annually	All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.
CI-D8-Q09 D8-Q09 60 days	**Close the material control weakness recorded for "Sensitive access and administrator rights are reviewed periodically".**	IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	STATE 2	Identity and Access Management Information Security / Internal Audit	Quarterly and after material role or system change	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.
CI-D8-Q10 D8-Q10 90 days	**Close the material control weakness recorded for "The organisation can investigate and contain identity misuse, account takeover or impersonation".**	Security Operations and Fraud Operations must maintain a response runbook for identity misuse covering session revocation, credential reset, account hold, customer or employee contact, evidence preservation, scope assessment, recovery, escalation and closure; the runbook is exercised periodically and material cases receive independent review.	STATE 1	Security Operations and Fraud Operations Information Security / Risk	On every suspected case; annual or post-incident exercise	Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.

Evidence requirement register

What management should be able to produce for each recommended control. No evidence has been requested, received or examined.

Identity and access challenge

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-D3-Q04	**Access requests and approvals**	Whether the access requests and approvals provides operating evidence that System and data access is granted against current role requirements is implemented across the complete in-scope population.	Approval predates provisioning	Business system owners Quarterly and on every joiner, mover or leaver event
	Current role-to-access matrix	Whether the current role-to-access matrix provides operating evidence that System and data access is granted against current role requirements; System and data access is reviewed periodically and removed when no longer required is implemented across the complete in-scope population.	Approval predates provisioning	Business system owners Quarterly and on every joiner, mover or leaver event
	Provisioning audit trail	Whether the provisioning audit trail provides operating evidence that System and data access is granted against current role requirements is implemented across the complete in-scope population.	Approval predates provisioning	Business system owners Quarterly and on every joiner, mover or leaver event
	Segregation-of-duties exception decisions	Whether the segregation-of-duties exception decisions provides operating evidence that System and data access is granted against current role requirements is implemented across the complete in-scope population.	Approval predates provisioning	Business system owners Quarterly and on every joiner, mover or leaver event
CI-D8-Q08	**Alert definitions for takeover indicators**	Whether the alert definitions for takeover indicators provides operating evidence that The organisation can detect identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Covers authentication, profile change and transaction events together	Security operations with identity owners Continuous logging and alerting; runbook exercised at least annually
	Defined retention period and data-protection basis	Whether the defined retention period and data-protection basis provides operating evidence that The organisation can detect identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Covers authentication, profile change and transaction events together	Security operations with identity owners Continuous logging and alerting; runbook exercised at least annually
	Investigation runbook and a worked case example	Whether the investigation runbook and a worked case example provides operating evidence that The organisation can detect identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Covers authentication, profile change and transaction events together	Security operations with identity owners Continuous logging and alerting; runbook exercised at least annually
	Log coverage inventory for identity-bearing systems	Whether the log coverage inventory for identity-bearing systems provides operating evidence that The organisation can detect identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Covers authentication, profile change and transaction events together	Security operations with identity owners Continuous logging and alerting; runbook exercised at least annually
CI-D8-Q09	**Complete sensitive-access register**	Whether the complete sensitive-access register provides operating evidence that Sensitive access and administrator rights are reviewed periodically is implemented across the complete in-scope population.	Reconciles to the complete population	Identity and Access Management Quarterly and after material role or system change

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	CHARACTERISTIC	OWNER / RECENCY
	Quarterly recertification decisions	Whether the quarterly recertification decisions provides operating evidence that Sensitive access and administrator rights are reviewed periodically is implemented across the complete in-scope population.	Reconciles to the complete population	Identity and Access Management Quarterly and after material role or system change
	Role and business-justification evidence	Whether the role and business-justification evidence provides operating evidence that Sensitive access and administrator rights are reviewed periodically is implemented across the complete in-scope population.	Reconciles to the complete population	Identity and Access Management Quarterly and after material role or system change
CI-D3-Q08	**Complete user-access export**	Whether the complete user-access export provides operating evidence that System and data access is reviewed periodically and removed when no longer required is implemented across the complete in-scope population.	Covers the complete active-user population	Business system owners Quarterly and on every joiner, mover or leaver event
	Periodic review decisions	Whether the periodic review decisions provides operating evidence that System and data access is reviewed periodically and removed when no longer required is implemented across the complete in-scope population.	Covers the complete active-user population	Business system owners Quarterly and on every joiner, mover or leaver event
	Removal and exception tickets	Whether the removal and exception tickets provides operating evidence that Sensitive access and administrator rights are reviewed periodically; System and data access is reviewed periodically and removed when no longer required is implemented across the complete in-scope population.	Covers the complete active-user population	Business system owners / Identity and Access Management Quarterly and after material role or system change; Quarterly and on every joiner, mover or leaver event
CI-D8-Q01	**Defined verification risk points and required checks**	Whether the defined verification risk points and required checks provides operating evidence that The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm is implemented across the complete in-scope population.	Retention respects applicable data-protection obligations	Process owners for onboarding and activation At every defined risk point and on sensitive change
	Exception approvals	Whether the exception approvals provides operating evidence that The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm is implemented across the complete in-scope population.	Retention respects applicable data-protection obligations	Process owners for onboarding and activation At every defined risk point and on sensitive change
	re-verification records for sensitive changes	Whether the re-verification records for sensitive changes provides operating evidence that The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm is implemented across the complete in-scope population.	Retention respects applicable data-protection obligations	Process owners for onboarding and activation At every defined risk point and on sensitive change
	Verification records with source and date	Whether the verification records with source and date provides operating evidence that The organisation verifies the identity of customers, users, employees, suppliers or counterparties where identity misuse could create fraud loss or harm is implemented across the complete in-scope population.	Retention respects applicable data-protection obligations	Process owners for onboarding and activation At every defined risk point and on sensitive change

Supplier and payment integrity

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	CHARACTERISTIC	OWNER / RECENCY
CI-D7-Q05	**Action log with owners**	Whether the action log with owners provides operating evidence that High-risk suppliers or third-party relationships are periodically monitored or reviewed is implemented across the complete in-scope population.	Covers the complete high-risk population	Procurement / Vendor Risk Risk-based cycle, at minimum annually for high-risk third parties
	Performance and pricing review records	Whether the performance and pricing review records provides operating evidence that High-risk suppliers or third-party relationships are periodically monitored or reviewed is implemented across the complete in-scope population.	Covers the complete high-risk population	Procurement / Vendor Risk Risk-based cycle, at minimum annually for high-risk third parties
	Re-screening results for ownership and sanctions	Whether the re-screening results for ownership and sanctions provides operating evidence that High-risk suppliers or third-party relationships are periodically monitored or reviewed is implemented across the complete in-scope population.	Covers the complete high-risk population	Procurement / Vendor Risk Risk-based cycle, at minimum annually for high-risk third parties
	Risk-tiered monitoring schedule	Whether the risk-tiered monitoring schedule provides operating evidence that High-risk suppliers or third-party relationships are periodically monitored or reviewed is implemented across the complete in-scope population.	Covers the complete high-risk population	Procurement / Vendor Risk Risk-based cycle, at minimum annually for high-risk third parties
	Spend concentration analysis	Whether the spend concentration analysis provides operating evidence that High-risk suppliers or third-party relationships are periodically monitored or reviewed is implemented across the complete in-scope population.	Covers the complete high-risk population	Procurement / Vendor Risk Risk-based cycle, at minimum annually for high-risk third parties
CI-D7-Q06	**Award and exception pattern analysis by individual**	Whether the award and exception pattern analysis by individual provides operating evidence that Procurement or vendor-management activity is subject to oversight or periodic review is implemented across the complete in-scope population.	Covers vendor-master changes and award patterns by individual	Internal Audit or independent reviewer At least annually, with continuous vendor-master change logging
	Findings tracked to closure	Whether the findings tracked to closure provides operating evidence that Procurement or vendor-management activity is subject to oversight or periodic review is implemented across the complete in-scope population.	Covers vendor-master changes and award patterns by individual	Internal Audit or independent reviewer At least annually, with continuous vendor-master change logging
	Independent review scope and report	Whether the independent review scope and report provides operating evidence that Procurement or vendor-management activity is subject to oversight or periodic review is implemented across the complete in-scope population.	Covers vendor-master changes and award patterns by individual	Internal Audit or independent reviewer At least annually, with continuous vendor-master change logging
	Vendor-master change log with approvers	Whether the vendor-master change log with approvers provides operating evidence that Procurement or vendor-management activity is subject to oversight or periodic review is implemented across the complete in-scope population.	Covers vendor-master changes and award patterns by individual	Internal Audit or independent reviewer At least annually, with continuous vendor-master change logging
CI-D7-Q02	**Award concentration and pricing-pattern analysis**	Whether the award concentration and pricing-pattern analysis provides operating evidence that Procurement processes include safeguards against collusion, manipulation, bid rigging or favouritism is implemented across the complete in-scope population.	Criteria demonstrably pre-date bid opening	Procurement lead Per qualifying sourcing event; award-pattern analysis at least twice a year
	Panel conflict declarations and scoring sheets	Whether the panel conflict declarations and scoring sheets provides operating evidence that Procurement processes include safeguards against collusion, manipulation, bid rigging or favouritism is implemented across the complete in-scope population.	Criteria demonstrably pre-date bid opening	Procurement lead Per qualifying sourcing event; award-pattern analysis at least twice a year

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	CHARACTERISTIC	OWNER / RECENCY
	Pre-set evaluation criteria dated before submission opening	Whether the pre-set evaluation criteria dated before submission opening provides operating evidence that Procurement processes include safeguards against collusion, manipulation, bid rigging or favouritism is implemented across the complete in-scope population.	Criteria demonstrably pre-date bid opening	Procurement lead Per qualifying sourcing event; award-pattern analysis at least twice a year
	Sealed-bid opening records with witnesses	Whether the sealed-bid opening records with witnesses provides operating evidence that Procurement processes include safeguards against collusion, manipulation, bid rigging or favouritism is implemented across the complete in-scope population.	Criteria demonstrably pre-date bid opening	Procurement lead Per qualifying sourcing event; award-pattern analysis at least twice a year
	Single-source justifications and approvals	Whether the single-source justifications and approvals provides operating evidence that Procurement processes include safeguards against collusion, manipulation, bid rigging or favouritism is implemented across the complete in-scope population.	Criteria demonstrably pre-date bid opening	Procurement lead Per qualifying sourcing event; award-pattern analysis at least twice a year

Culture and continuous improvement

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-D8-Q06	**Defined response-time targets**	Whether the defined response-time targets provides operating evidence that Employees and users know how to report suspicious digital activity or account-security concerns is implemented across the complete in-scope population.	Covers both internal staff and external users where relevant	Security operations Continuous intake within defined monitored hours
	Evidence reports feed into triage and incident response	Whether the evidence reports feed into triage and incident response provides operating evidence that Employees and users know how to report suspicious digital activity or account-security concerns is implemented across the complete in-scope population.	Covers both internal staff and external users where relevant	Security operations Continuous intake within defined monitored hours
	Published reporting routes for staff and users	Whether the published reporting routes for staff and users provides operating evidence that Employees and users know how to report suspicious digital activity or account-security concerns is implemented across the complete in-scope population.	Covers both internal staff and external users where relevant	Security operations Continuous intake within defined monitored hours
	Report register with response times	Whether the report register with response times provides operating evidence that Employees and users know how to report suspicious digital activity or account-security concerns is implemented across the complete in-scope population.	Covers both internal staff and external users where relevant	Security operations Continuous intake within defined monitored hours
CI-D8-Q03	**Reporting route usage statistics**	Whether the reporting route usage statistics provides operating evidence that Employees receive training on phishing, social engineering and digital impersonation attempts is implemented across the complete in-scope population.	Links to an out-of-band verification requirement	Security awareness owner At induction, at least annually, with periodic simulations
	Role-relevant training content and completion records	Whether the role-relevant training content and completion records provides operating evidence that Employees receive training on phishing, social engineering and digital impersonation attempts is implemented across the complete in-scope population.	Links to an out-of-band verification requirement	Security awareness owner At induction, at least annually, with periodic simulations

FICTIONAL COMPARISON. MFRS V1.2 answers derived from a fictional organisation; scored by the existing calculator. Not a customer report.

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	CHARACTERISTIC	OWNER / RECENCY
	Simulation results including click and report rates	Whether the simulation results including click and report rates provides operating evidence that Employees receive training on phishing, social engineering and digital impersonation attempts is implemented across the complete in-scope population.	Links to an out-of-band verification requirement	Security awareness owner At induction, at least annually, with periodic simulations
	Verification procedure for payment and bank-detail instructions	Whether the verification procedure for payment and bank-detail instructions provides operating evidence that Employees receive training on phishing, social engineering and digital impersonation attempts is implemented across the complete in-scope population.	Links to an out-of-band verification requirement	Security awareness owner At induction, at least annually, with periodic simulations

payroll integrity

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-D3-Q09	**Duplicate and ghost-record exception report**	Whether the duplicate and ghost-record exception report provides operating evidence that Payroll master-file changes and unusual payroll records receive review before payment is implemented across the complete in-scope population.	Covers the complete payment-run population	Payroll and Human Resources Before every payroll payment run; monthly trend review
	Exception closure evidence	Whether the exception closure evidence provides operating evidence that Payroll master-file changes and unusual payroll records receive review before payment is implemented across the complete in-scope population.	Covers the complete payment-run population	Payroll and Human Resources Before every payroll payment run; monthly trend review
	Joiner/mover/leaver reconciliation	Whether the joiner/mover/leaver reconciliation provides operating evidence that Payroll master-file changes and unusual payroll records receive review before payment is implemented across the complete in-scope population.	Covers the complete payment-run population	Payroll and Human Resources Before every payroll payment run; monthly trend review
	Payroll master-file change report	Whether the payroll master-file change report provides operating evidence that Payroll master-file changes and unusual payroll records receive review before payment is implemented across the complete in-scope population.	Covers the complete payment-run population	Payroll and Human Resources Before every payroll payment run; monthly trend review
	Pre-payroll review sign-off	Whether the pre-payroll review sign-off provides operating evidence that Payroll master-file changes and unusual payroll records receive review before payment is implemented across the complete in-scope population.	Covers the complete payment-run population	Payroll and Human Resources Before every payroll payment run; monthly trend review

cash custody

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-D3-Q10	**Banking and receipt reconciliation**	Whether the banking and receipt reconciliation provides operating evidence that Physical cash is counted, safeguarded and reconciled by defined people is implemented across the complete in-scope population.	Counts are attributable and time-stamped	Site operations and Finance Each cash-handling shift/day; monthly exception and trend review
	Cash custody register	Whether the cash custody register provides operating evidence that Physical cash is counted, safeguarded and reconciled by defined people is implemented across the complete in-scope population.	Counts are attributable and time-stamped	Site operations and Finance Each cash-handling shift/day; monthly exception and trend review

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	CHARACTERISTIC	OWNER / RECENCY
	Count sheets and independent checks	Whether the count sheets and independent checks provides operating evidence that Physical cash is counted, safeguarded and reconciled by defined people is implemented across the complete in-scope population.	Counts are attributable and time-stamped	Site operations and Finance Each cash-handling shift/day; monthly exception and trend review
	Sealed transfer records	Whether the sealed transfer records provides operating evidence that Physical cash is counted, safeguarded and reconciled by defined people is implemented across the complete in-scope population.	Counts are attributable and time-stamped	Site operations and Finance Each cash-handling shift/day; monthly exception and trend review
	Shortage/overage investigation log	Whether the shortage/overage investigation log provides operating evidence that Physical cash is counted, safeguarded and reconciled by defined people is implemented across the complete in-scope population.	Counts are attributable and time-stamped	Site operations and Finance Each cash-handling shift/day; monthly exception and trend review

stock asset custody

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-D3-Q11	**Complete stock and asset register**	Whether the complete stock and asset register provides operating evidence that Stock and physical assets are safeguarded and reconciled by defined people is implemented across the complete in-scope population.	Count differences and write-offs have independent review	Operations, Stores and Asset Management Movement on each event; periodic counts; monthly exception review
	Count sheets and reconciliation	Whether the count sheets and reconciliation provides operating evidence that Stock and physical assets are safeguarded and reconciled by defined people is implemented across the complete in-scope population.	Count differences and write-offs have independent review	Operations, Stores and Asset Management Movement on each event; periodic counts; monthly exception review
	Custodian assignments	Whether the custodian assignments provides operating evidence that Stock and physical assets are safeguarded and reconciled by defined people is implemented across the complete in-scope population.	Count differences and write-offs have independent review	Operations, Stores and Asset Management Movement on each event; periodic counts; monthly exception review
	Movement and disposal records	Whether the movement and disposal records provides operating evidence that Stock and physical assets are safeguarded and reconciled by defined people is implemented across the complete in-scope population.	Count differences and write-offs have independent review	Operations, Stores and Asset Management Movement on each event; periodic counts; monthly exception review
	Write-off and shrinkage review	Whether the write-off and shrinkage review provides operating evidence that Stock and physical assets are safeguarded and reconciled by defined people is implemented across the complete in-scope population.	Count differences and write-offs have independent review	Operations, Stores and Asset Management Movement on each event; periodic counts; monthly exception review

Detection and exception review

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-D8-Q02	**Alert case records**	Whether suspicious digital-activity alerts are assigned, investigated, dispositioned and escalated to the required service level.	Maps each rule to a risk and SLA	Security monitoring / SOC Continuous monitoring; monthly rule tuning
	In-scope event inventory	Whether the complete population of priority login, access, profile and transaction events has been identified for monitoring.	Maps each rule to a risk and SLA	Security monitoring / SOC Continuous monitoring; monthly rule tuning

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	CHARACTERISTIC	OWNER / RECENCY
	Monitoring-rule catalogue	Whether the monitoring-rule catalogue provides operating evidence that The organisation monitors suspicious access, account or transaction behaviour across its relevant systems and digital channels, including through provider reporting where a third party operates the channel is implemented across the complete in-scope population.	Maps each rule to a risk and SLA	Security monitoring / SOC Continuous monitoring; monthly rule tuning
	Monthly tuning and coverage report	Whether the monthly tuning and coverage report provides operating evidence that The organisation monitors suspicious access, account or transaction behaviour across its relevant systems and digital channels, including through provider reporting where a third party operates the channel is implemented across the complete in-scope population.	Maps each rule to a risk and SLA	Security monitoring / SOC Continuous monitoring; monthly rule tuning

Incident response and evidence integrity

CONTROL	EVIDENCE REQUIRED	WHAT IT SHOULD PROVE	MINIMUM ACCEPTABLE CHARACTERISTIC	OWNER / RECENCY
CI-D8-Q10	**Authentication and activity evidence**	Whether the authentication and activity evidence provides operating evidence that The organisation can investigate and contain identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Closure or recovery decision is recorded	Security Operations and Fraud Operations On every suspected case; annual or post-incident exercise
	Containment and investigation case records	Whether the containment and investigation case records provides operating evidence that The organisation can investigate and contain identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Closure or recovery decision is recorded	Security Operations and Fraud Operations On every suspected case; annual or post-incident exercise
	Exercise and lessons-learned records	Whether the exercise and lessons-learned records provides operating evidence that The organisation can investigate and contain identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Closure or recovery decision is recorded	Security Operations and Fraud Operations On every suspected case; annual or post-incident exercise
	Identity-misuse response runbook	Whether the identity-misuse response runbook provides operating evidence that The organisation can investigate and contain identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Closure or recovery decision is recorded	Security Operations and Fraud Operations On every suspected case; annual or post-incident exercise
	Recovery or notification decisions	Whether the recovery or notification decisions provides operating evidence that The organisation can investigate and contain identity misuse, account takeover or impersonation is implemented across the complete in-scope population.	Closure or recovery decision is recorded	Security Operations and Fraud Operations On every suspected case; annual or post-incident exercise

12-month action and assurance register

The full twelve-month programme. Not every row is initial implementation: later horizons operate each control through its required cycle and then review whether it is still effective. The work type on each row says which it is.

HORIZON	WORK TYPE	ACTION	OWNER	COMPLETION CRITERION	EFFECTIVENESS MEASURE
60 days	Implement	Apply immediate escalation at "Any missed quarterly review, unassigned account or removal overdue beyond 10 business days." and deliver the exact control design: System owners must maintain a current role-to-access matrix, require business-owner approval against the requester's current duties before granting access, separate incompatible initiation and approval rights, and retain the request, approval and provisioning trail.	COO	Access requests and approvals; Current role-to-access matrix; Provisioning audit trail; Segregation-of-duties exception decisions	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
60 days	Implement	Apply immediate escalation at "Activation before verification, an unapproved exception, or a sensitive change without re-verification." and deliver the exact control design: The process owner must define the risk points requiring verification, including customer or beneficiary enrolment, employee onboarding, supplier activation and counterparty contracting. Apply proportionate checks against independent sources such as identity documents validated for authenticity, company registration records and confirmation of contact details through independently obtained channels. Retain results and evidence under applicable data-protection obligations, require documented approval for exceptions, and trigger re-verification for sensitive profile or banking changes.	COO / CFO	Defined verification risk points and required checks; Exception approvals; re-verification records for sensitive changes; Verification records with source and date	100% of in-scope enrolments and activations carry completed verification before activation, with all exceptions approved.
60 days	Implement	Apply immediate escalation at "A suspected compromise report unactioned beyond target, or no route published for a live user-facing channel." and deliver the exact control design: The security operations owner must publish a clearly signposted route for staff and, where relevant, external users to report suspicious messages, unexpected account changes and suspected compromise, define monitored hours and target response times, connect reports directly into the alert triage and incident-response process, provide acknowledgement and outcome feedback, and track reporting volume and response time against target.	Chief Technology Officer	Defined response-time targets; Evidence reports feed into triage and incident response; Published reporting routes for staff and users; Report register with response times	At least 95% of reports acknowledged within the target time and routed into triage.

60 days	Implement	Apply immediate escalation at "A sensitive payroll change released without review, unexplained duplicate or ghost record, or unresolved exception at payment release." and deliver the exact control design: Payroll and Human Resources must reconcile joiner, mover and leaver records to the payroll master file before each payment run, independently review bank-account and pay-rate changes, test for duplicate or ghost records and unusual payments, and retain reviewer decisions and exception closure before release.	Chief Financial Officer / Chief People Officer	Duplicate and ghost-record exception report; Exception closure evidence; Joiner/mover/leaver reconciliation; Payroll master-file change report; Pre-payroll review sign-off	Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.
60 days	Implement	Apply immediate escalation at "Unexplained shortage or overage above threshold, missing count or unreconciled banking." and deliver the exact control design: Finance and site managers must assign cash custodians, perform opening and closing counts with independent review, reconcile takings to receipts and bankings, record sealed transfers and investigate every shortage or overage against a defined threshold before the next cycle closes.	Chief Financial Officer / Chief Operating Officer	Banking and receipt reconciliation; Cash custody register; Count sheets and independent checks; Sealed transfer records; Shortage/overage investigation log	All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.
60 days	Implement	Apply immediate escalation at "Criteria set or changed after bid opening, an undeclared conflict, or unjustified single-source award." and deliver the exact control design: The procurement owner must require, above defined thresholds, that evaluation criteria and weightings are fixed and recorded before submissions are opened, submissions remain sealed until a scheduled opening witnessed by at least two people, evaluation is performed by a panel with signed conflict declarations, and single-source or emergency awards require documented justification and independent approval; a periodic analysis reviews award concentration, repeated near-identical pricing and rotating winners.	CFO / COO	Award concentration and pricing-pattern analysis; Panel conflict declarations and scoring sheets; Pre-set evaluation criteria dated before submission opening; Sealed-bid opening records with witnesses; Single-source justifications and approvals	100% of above-threshold awards follow the documented competitive process with declared conflicts and justified exceptions.
60 days	Implement	Apply immediate escalation at "Unknown or unjustified access, missed review, or removal overdue beyond the agreed service level." and deliver the exact control design: IT Security must reconcile the complete sensitive-access and administrator population to current owners and role requirements at least quarterly, obtain an independent keep/remove decision from system owners, record exceptions and close removals within the defined service level; emergency and service accounts are included.	Chief Technology Officer	Complete sensitive-access register; Quarterly recertification decisions; Removal and exception tickets; Role and business-justification evidence	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.

60 days	Implement	Apply immediate escalation at "Missed review, unknown access or removal overdue beyond the defined service level." and deliver the exact control design: System owners must export the complete active-user access population on a defined cycle, obtain business-owner keep/remove decisions against current responsibilities, route exceptions to IT for closure and reconcile leaver and mover removals to the HR feed.	COO	Complete user-access export; Current role-to-access matrix; Periodic review decisions; Removal and exception tickets	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.
90 days	Implement	Apply immediate escalation at "Priority feed outage, high-risk alert outside SLA or confirmed compromise not escalated." and deliver the exact control design: The security monitoring owner inventories material login, privilege, profile and transaction events, implements risk rules across the full in-scope event feed, assigns alerts to trained analysts, preserves dispositions and escalates high-risk account compromise immediately; monthly tuning uses confirmed true/false positives.	Chief Technology Officer	Alert case records; In-scope event inventory; Monitoring-rule catalogue; Monthly tuning and coverage report	All priority event feeds monitored and 95% of high-risk alerts triaged within SLA.
90 days	Implement	Apply immediate escalation at "A suspected takeover that cannot be reconstructed from logs, or a material system without identity logging." and deliver the exact control design: Security Operations must monitor authentication, credential, profile, device and transaction signals across material identity-bearing systems, define takeover indicators and alert thresholds, and route suspected identity misuse into the separate investigation and containment process.	Chief Technology Officer	Alert definitions for takeover indicators; Defined retention period and data-protection basis; Investigation runbook and a worked case example; Log coverage inventory for identity-bearing systems	All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.
90 days	Implement	Apply immediate escalation at "Review overdue, or a concentration of exceptions by one individual not investigated." and deliver the exact control design: The audit committee must commission periodic independent review of procurement and vendor management covering all vendor-master creations and amendments with approver identity, award patterns by buyer and supplier, spend outside approved contracts or thresholds, use of emergency and single-source routes, and policy exception volumes by individual; findings are reported to governance with owners and due dates and tracked to closure.	Audit Committee Chair / CFO	Award and exception pattern analysis by individual; Findings tracked to closure; Independent review scope and report; Vendor-master change log with approvers	An independent procurement and vendor-management review is completed each period with findings closed by due date.
90 days	Implement	Apply immediate escalation at "Material unexplained shrinkage, unsupported disposal or missed count at a high-risk location." and deliver the exact control design: Operations and Finance must maintain a complete stock and asset register, assign custodians, require authorised movement and disposal records, perform risk-based counts across locations, reconcile results to the ledger or inventory system and independently approve write-offs and investigate shrinkage exceptions.	Chief Operating Officer / Chief Financial Officer	Complete stock and asset register; Count sheets and reconciliation; Custodian assignments; Movement and disposal records; Write-off and shrinkage review	All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.

90 days	Implement	Apply immediate escalation at "A high-risk third party overdue for review, or an ownership change detected without reassessment." and deliver the exact control design: The vendor-risk owner must define a risk-based monitoring cycle in which high-risk third parties are re-screened for ownership and sanctions change, reviewed for delivery and quality performance, tested for pricing drift against benchmark or contract, and analysed for spend concentration and unusual growth; findings requiring action are logged with owners, and failure to complete a cycle triggers escalation to the CFO.	CFO / COO	Action log with owners; Performance and pricing review records; Re-screening results for ownership and sanctions; Risk-tiered monitoring schedule; Spend concentration analysis	100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.
90 days	Implement	Apply immediate escalation at "A high-risk role group with low report rate, or a real payment instruction actioned without out-of-band verification." and deliver the exact control design: The security awareness owner must deliver role-relevant training covering payment-instruction and bank-detail-change requests, executive impersonation, urgency and secrecy pressure, credential-harvesting pages and voice or messaging impersonation; reinforce with periodic simulations targeted at high-risk roles such as finance and procurement, measure report rate as well as click rate, provide a one-click reporting route with feedback, and require verification through an independently obtained channel for any payment or bank-detail instruction.	Chief Technology Officer / Chief People Officer	Reporting route usage statistics; Role-relevant training content and completion records; Simulation results including click and report rates; Verification procedure for payment and bank-detail instructions	At least 95% completion, improving report rate and declining click rate across successive simulations.
90 days	Implement	Apply immediate escalation at "Suspected takeover not contained within the defined SLA, incomplete evidence or unresolved affected-party exposure." and deliver the exact control design: Security Operations and Fraud Operations must maintain a response runbook for identity misuse covering session revocation, credential reset, account hold, customer or employee contact, evidence preservation, scope assessment, recovery, escalation and closure; the runbook is exercised periodically and material cases receive independent review.	Chief Technology Officer / Chief Operating Officer	Authentication and activity evidence; Containment and investigation case records; Exercise and lessons-learned records; Identity-misuse response runbook; Recovery or notification decisions	Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Quarterly and on every joiner, mover or leaver event), with a management sample and any exceptions recorded.	COO	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Quarterly and on every joiner, mover or leaver event), with a management sample and any exceptions recorded.	COO	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Before every payroll payment run; monthly trend review), with a management sample and any exceptions recorded.	Chief Financial Officer / Chief People Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.

3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Each cash-handling shift/day; monthly exception and trend review), with a management sample and any exceptions recorded.	Chief Financial Officer / Chief Operating Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Movement on each event; periodic counts; monthly exception review), with a management sample and any exceptions recorded.	Chief Operating Officer / Chief Financial Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Risk-based cycle, at minimum annually for high-risk third parties), with a management sample and any exceptions recorded.	CFO / COO	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (At least annually, with continuous vendor-master change logging), with a management sample and any exceptions recorded.	Audit Committee Chair / CFO	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	An independent procurement and vendor-management review is completed each period with findings closed by due date.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous monitoring; monthly rule tuning), with a management sample and any exceptions recorded.	Chief Technology Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	All priority event feeds monitored and 95% of high-risk alerts triaged within SLA.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (At induction, at least annually, with periodic simulations), with a management sample and any exceptions recorded.	Chief Technology Officer / Chief People Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	At least 95% completion, improving report rate and declining click rate across successive simulations.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous intake within defined monitored hours), with a management sample and any exceptions recorded.	Chief Technology Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	At least 95% of reports acknowledged within the target time and routed into triage.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Continuous logging and alerting; runbook exercised at least annually), with a management sample and any exceptions recorded.	Chief Technology Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (Quarterly and after material role or system change), with a management sample and any exceptions recorded.	Chief Technology Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.
3-6 months	Embed & evidence	Retained evidence covering one full operating cycle (On every suspected case; annual or post-incident exercise), with a management sample and any exceptions recorded.	Chief Technology Officer / Chief Operating Officer	The retained evidence covers the required population for the full cycle and exceptions are resolved or escalated.	Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.
6-12 months	Assure & review	A management or assurance review of CI-D3-Q04 covering effectiveness, exception trend and dependency, evidenced against: 100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.	COO	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.	100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.
6-12 months	Assure & review	A management or assurance review of CI-D3-Q08 covering effectiveness, exception trend and dependency, evidenced against: 100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.	COO	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.	100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.

6-12 months	Assure & review	A management or assurance review of CI-D3-Q09 covering effectiveness, exception trend and dependency, evidenced against: Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.	Chief Financial Officer / Chief People Officer	Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.	Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.
6-12 months	Assure & review	A management or assurance review of CI-D3-Q10 covering effectiveness, exception trend and dependency, evidenced against: All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.	Chief Financial Officer / Chief Operating Officer	All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.	All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.
6-12 months	Assure & review	A management or assurance review of CI-D3-Q11 covering effectiveness, exception trend and dependency, evidenced against: All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.	Chief Operating Officer / Chief Financial Officer	All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.	All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.
6-12 months	Assure & review	A management or assurance review of CI-D7-Q05 covering effectiveness, exception trend and dependency, evidenced against: 100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.	CFO / COO	100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.	100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.
6-12 months	Assure & review	A management or assurance review of CI-D7-Q06 covering effectiveness, exception trend and dependency, evidenced against: An independent procurement and vendor-management review is completed each period with findings closed by due date.	Audit Committee Chair / CFO	An independent procurement and vendor-management review is completed each period with findings closed by due date.	An independent procurement and vendor-management review is completed each period with findings closed by due date.
6-12 months	Assure & review	A management or assurance review of CI-D8-Q02 covering effectiveness, exception trend and dependency, evidenced against: All priority event feeds monitored and 95% of high-risk alerts triaged within SLA.	Chief Technology Officer	All priority event feeds monitored and 95% of high-risk alerts triaged within SLA.	All priority event feeds monitored and 95% of high-risk alerts triaged within SLA.
6-12 months	Assure & review	A management or assurance review of CI-D8-Q03 covering effectiveness, exception trend and dependency, evidenced against: At least 95% completion, improving report rate and declining click rate across successive simulations.	Chief Technology Officer / Chief People Officer	At least 95% completion, improving report rate and declining click rate across successive simulations.	At least 95% completion, improving report rate and declining click rate across successive simulations.
6-12 months	Assure & review	A management or assurance review of CI-D8-Q06 covering effectiveness, exception trend and dependency, evidenced against: At least 95% of reports acknowledged within the target time and routed into triage.	Chief Technology Officer	At least 95% of reports acknowledged within the target time and routed into triage.	At least 95% of reports acknowledged within the target time and routed into triage.
6-12 months	Assure & review	A management or assurance review of CI-D8-Q08 covering effectiveness, exception trend and dependency, evidenced against: All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.	Chief Technology Officer	All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.	All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.

6-12 months	Assure & review	A management or assurance review of CI-D8-Q09 covering effectiveness, exception trend and dependency, evidenced against: 100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.	Chief Technology Officer	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.	100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.
6-12 months	Assure & review	A management or assurance review of CI-D8-Q10 covering effectiveness, exception trend and dependency, evidenced against: Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.	Chief Technology Officer / Chief Operating Officer	Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.	Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.

Measurement register

The effectiveness test behind each recommended control, grouped by programme. These are the signals management should expect once the control operates.

Identity and access challenge

MEASURE	CONTROLS IT COVERS
100% population reviewed quarterly and 95% of removal exceptions closed within 10 business days.	CI-D3-Q04
100% of ordinary system and data access is reviewed on schedule and stale access is removed within the defined service level.	CI-D3-Q08
100% of in-scope enrolments and activations carry completed verification before activation, with all exceptions approved.	CI-D8-Q01
All material identity-bearing systems are logged with takeover alerting active and the runbook exercised annually.	CI-D8-Q08
100% of sensitive and administrator access is reviewed each quarter, with removals completed within the defined service level.	CI-D8-Q09

Supplier and payment integrity

MEASURE	CONTROLS IT COVERS
100% of above-threshold awards follow the documented competitive process with declared conflicts and justified exceptions.	CI-D7-Q02
100% of high-risk third parties reviewed within the defined cycle with findings actioned by due date.	CI-D7-Q05
An independent procurement and vendor-management review is completed each period with findings closed by due date.	CI-D7-Q06

Culture and continuous improvement

MEASURE	CONTROLS IT COVERS
At least 95% completion, improving report rate and declining click rate across successive simulations.	CI-D8-Q03
At least 95% of reports acknowledged within the target time and routed into triage.	CI-D8-Q06

payroll integrity

MEASURE	CONTROLS IT COVERS
Every payroll run has a completed independent pre-payment review with all exceptions resolved or formally escalated.	CI-D3-Q09

cash custody

MEASURE	CONTROLS IT COVERS
All cash points reconcile each cycle, with every difference investigated and resolved or escalated within the defined period.	CI-D3-Q10

stock asset custody

MEASURE	CONTROLS IT COVERS
All material stock and physical assets are counted and reconciled on schedule, with shrinkage and write-offs independently reviewed.	CI-D3-Q11

Detection and exception review

MEASURE	CONTROLS IT COVERS
All priority event feeds monitored and 95% of high-risk alerts triaged within SLA.	CI-D8-Q02

MEASURE	CONTROLS IT COVERS
Every suspected identity-misuse case has timely containment, a recorded investigation and an accountable closure decision.	CI-D8-Q10